Threat-hunt-using-Splunk Detecting Adversary Reconnaissance

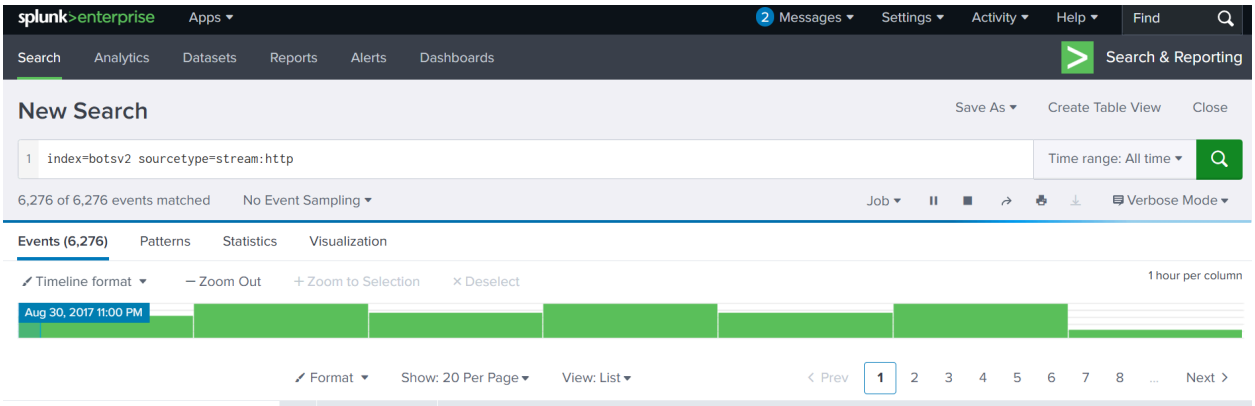
Scenario:

Intelligence Input: Law enforcement warned of a campaign targeting our industry. The adversary is conducting reconnaissance on public-facing web servers using a non-standard browser over port 80 to bypass traditional signature-based detection.

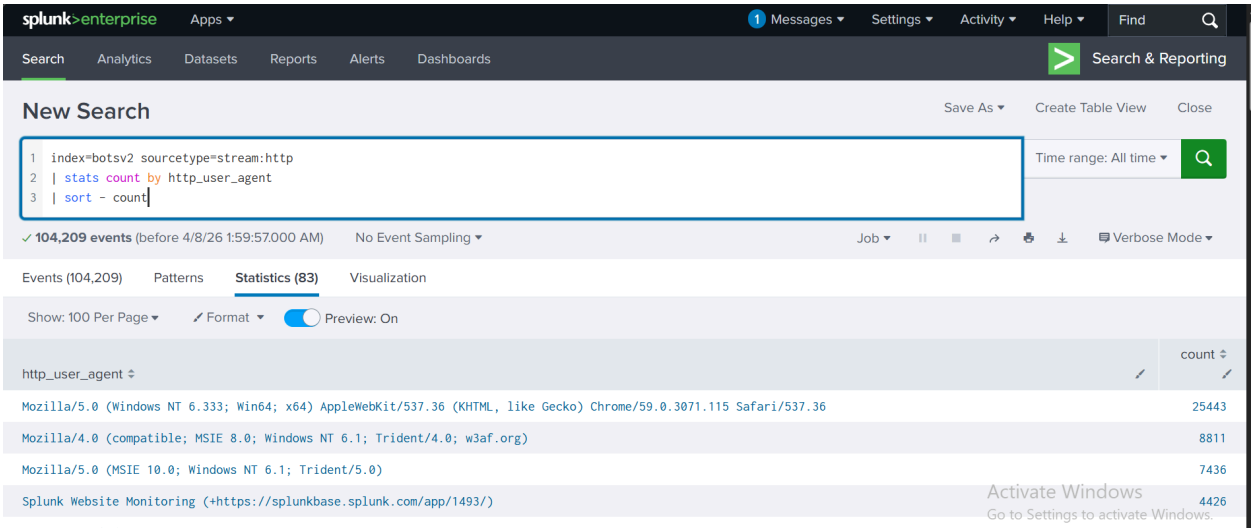
Tech stack & Lab Environment

- SIEM: Splunk
- Dataset: BOTSV2(Attack only)
- Enrichment: ipinfo and whatismybrower (for geographical and useragent infomation).
- Environment: Window
- Analysis Focus: IP Geographical, user-agent, ASN Reputations.

Based on the event that occurred the source type will be “http”(port:80) for insecure website as shown below



Due to the high traffic and reconnaissance conduct by the user I filter based on user_agent to detect anomalous using the query stats(statistics) and sort in descending order to check the one with rare and high traffic/count.



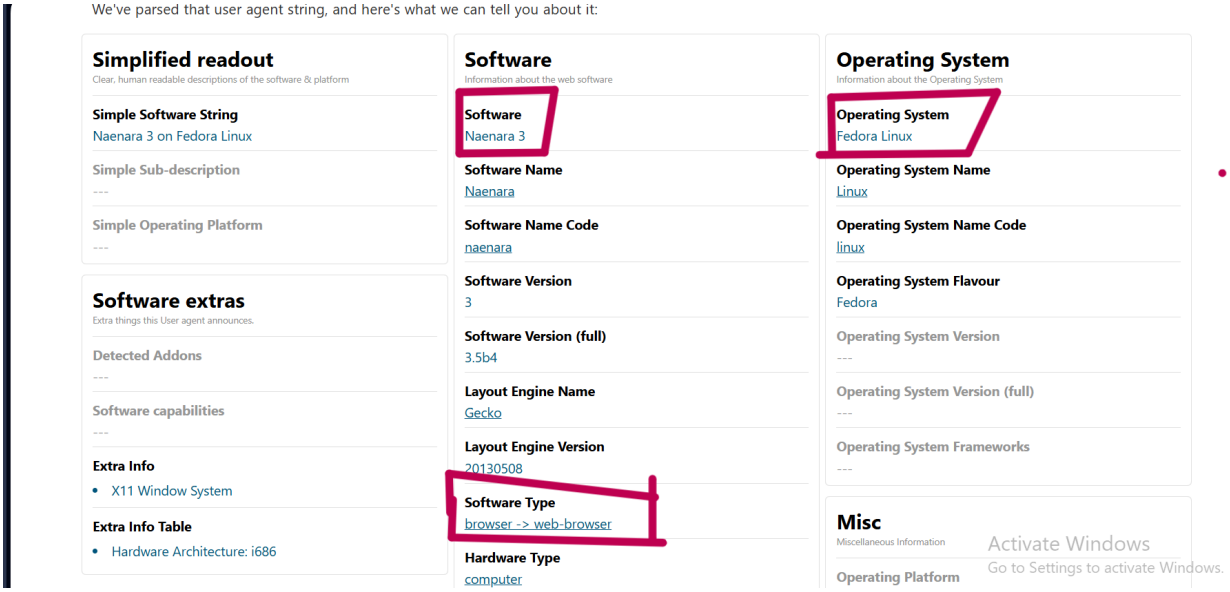
The suspicious User_agent : .(Mozilla/5.0 (X11; U; Linux i686; ko-KP; rv: 19.1br) Gecko/20130508 Fedora/1.9.1-2.5.rs3.0 NaenaraBrowser/3.5b4") Is highlighted red in the picture below.

```
Mozilla/5.0 Jorgee
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/51.0.2704.79 Safari/537.36 Edge/14.14393
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/59.0.3071.115 Safari/537.36
Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:54.0) Gecko/20100101 Firefox/54.0
Microsoft Office/16.0 (Windows NT 6.1; Microsoft PowerPoint 16.0.8229; Pro)
Mozilla/5.0 (X11; U; Linux i686; ko-KP; rv: 19.1br) Gecko/20130508 Fedora/1.9.1-2.5.rs3.0 NaenaraBrowser/3.5b4
```

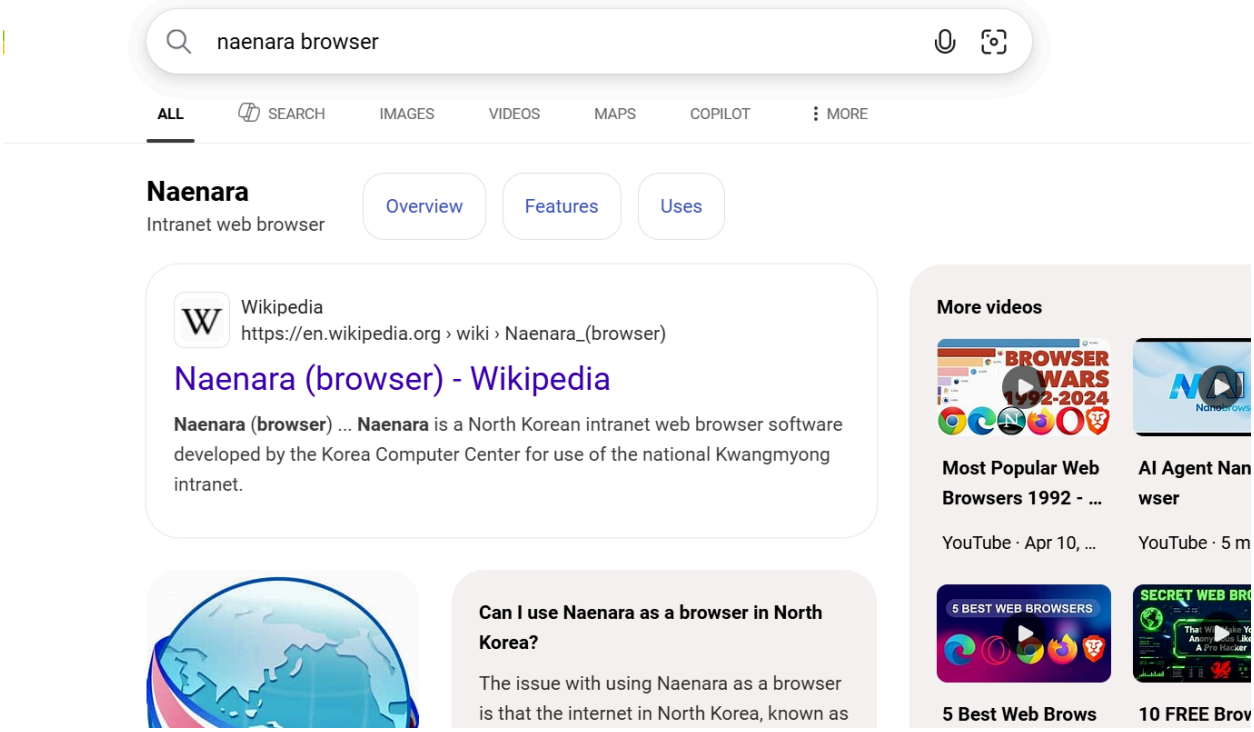
Using an open source website, linked below, to get concrete information about the user agent

https://explore.whatismybrowser.com/useragents/parse/

The full detail of the agent show in the picture below , get the important details like the software (Naenara) operating system and software type (browser).

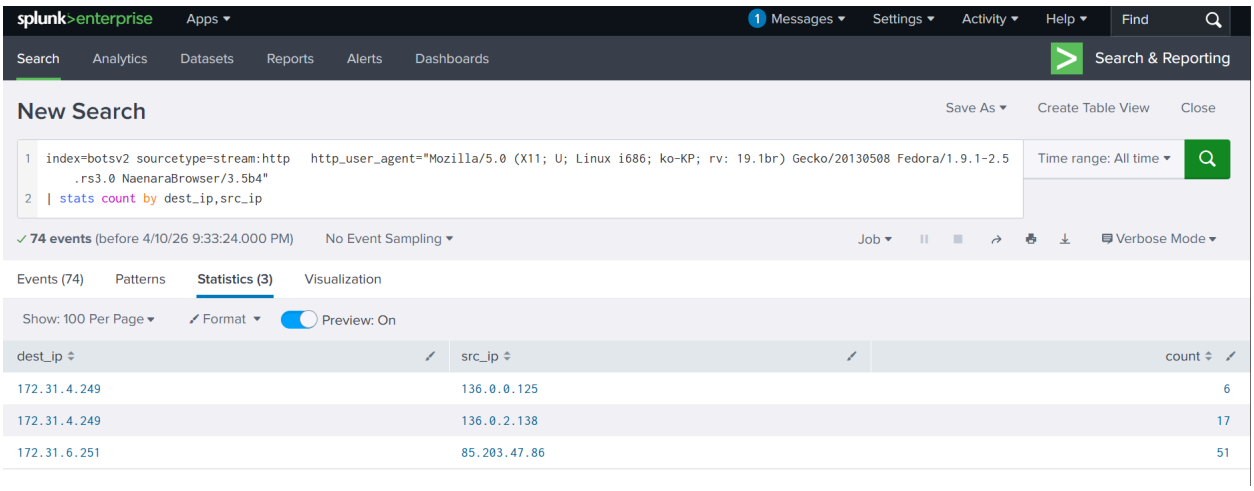


As seen above, the Naenara browser is being run from a Fedora Linux system. The Linux system is not uncommon; after checking Naenara on google it show in the picture below that it belong to “North Korea” web browser.



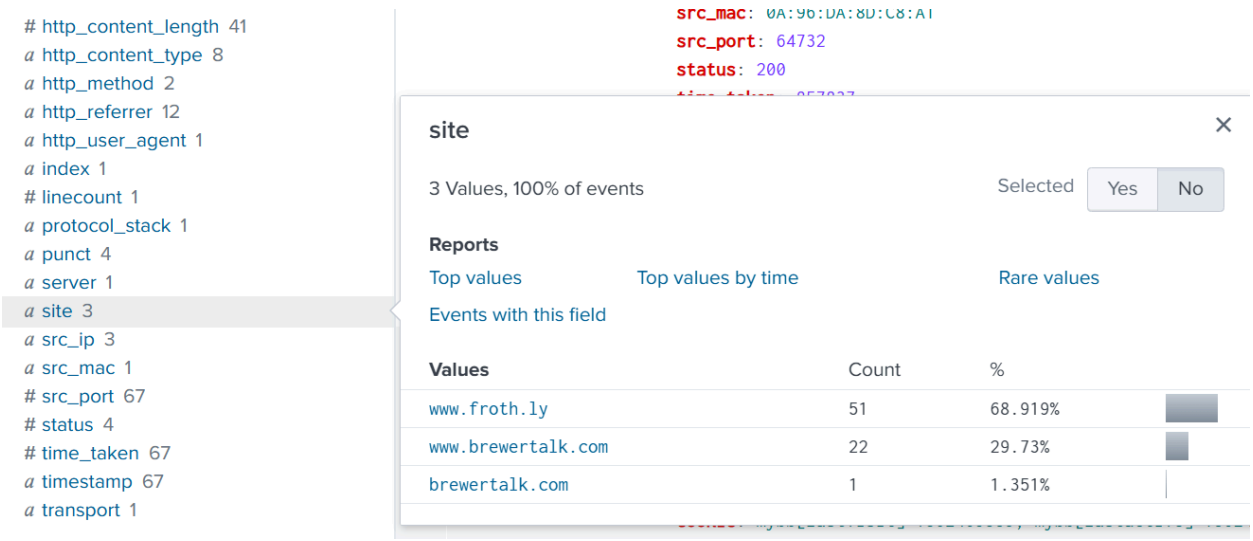
The user agent belong to North Korea which increase the tense of suspicious but can't conclude based on this, more information needed to be gather like the IP address to compare if it matches the same region as North Korea.

The query in the picture revile the IPs address that belong to the user_agent

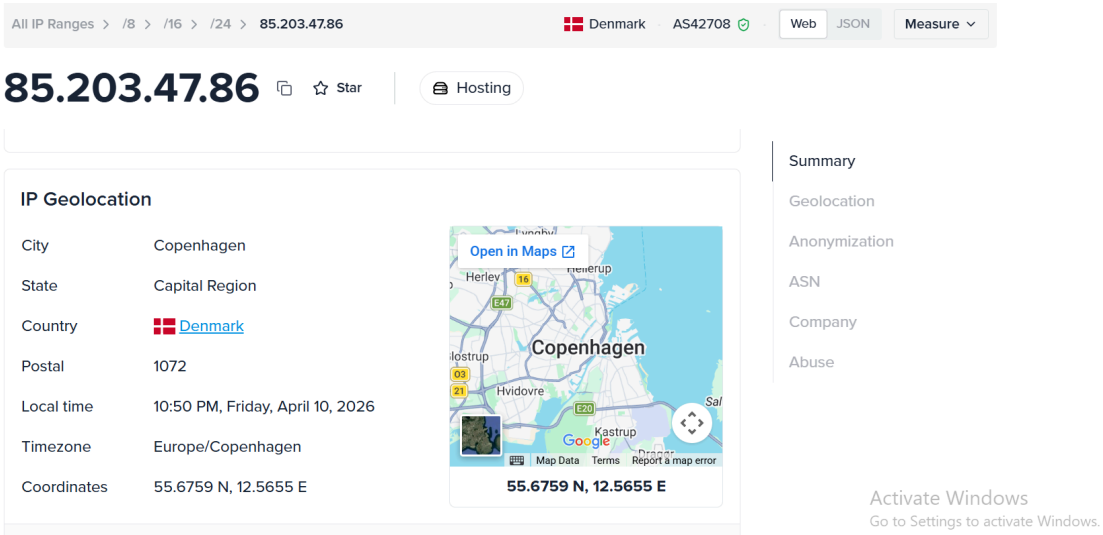


from the above result there IPs addresses belong to the user_agent i investigate the one with higher count.

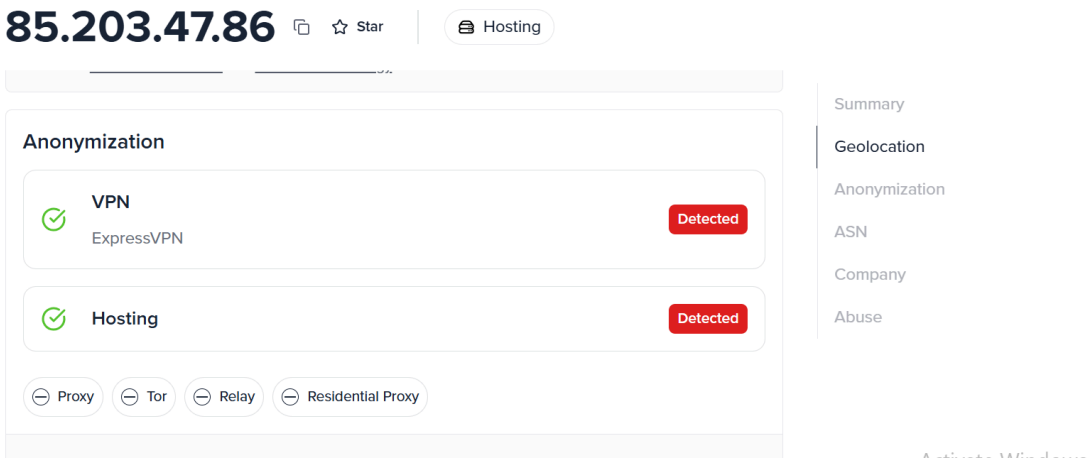
accessed The IPs are communicated with these sites I focus on www.froth.ly because the count us high. .



We can then research the IP address using open source intelligence. Using IPinfo.io, with a free account, we can research the IP address 85.203.47.86. It show that the geographical location(country) is DK(**Denmark)**



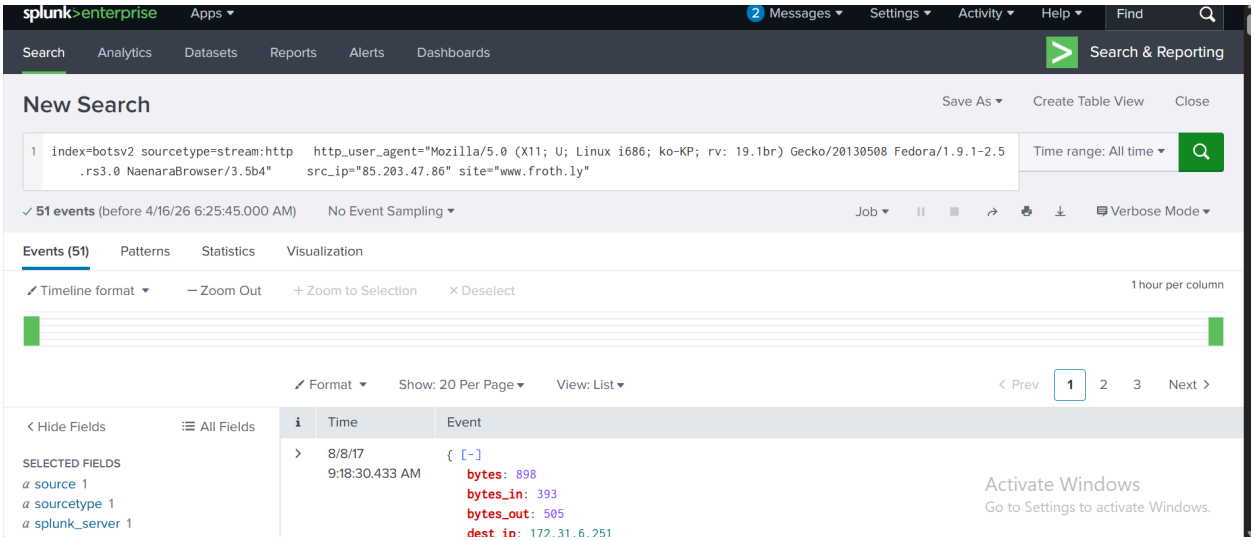
As seen below the IP 85.203.47.89 belong to ExpressVPN one the strong VPN for routing,

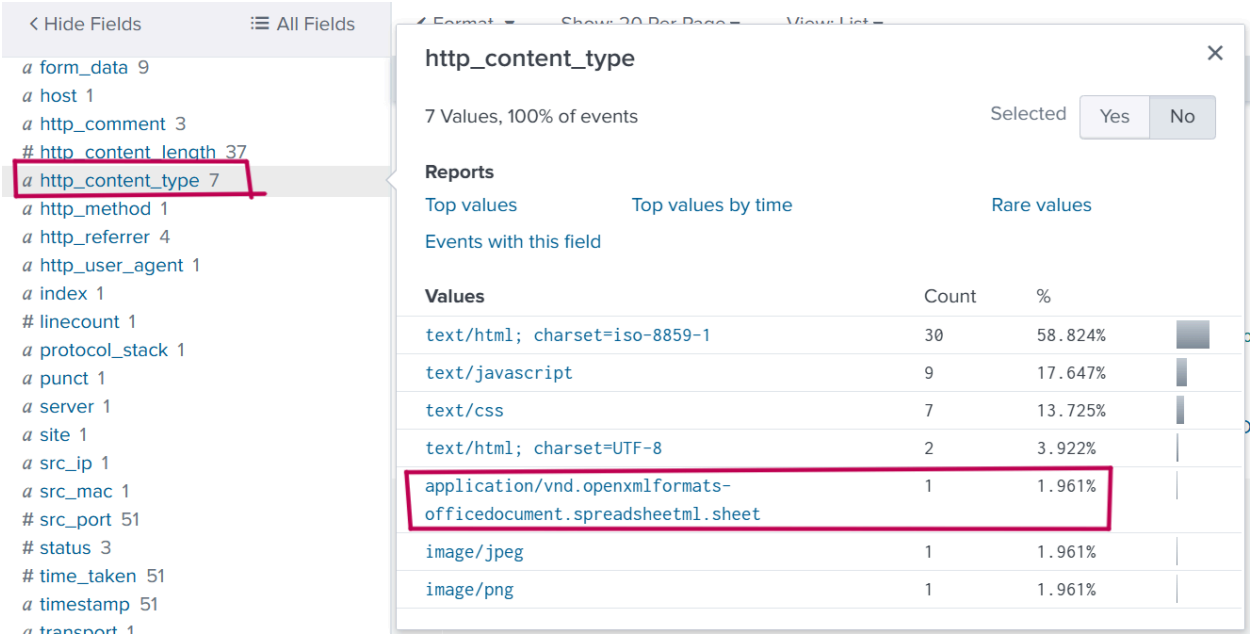


The VPN make the hunt more complicated because the user browser is from North Korea and the geographical location say Denmark which implies inconsistent fingerprint and inaccurate attribution.

Note: Activity should be analyzed based on behavioral indicators rather than geolocation only.

I continue the hunt by checking activities of the user which include the accessed files, URI path, the file accessed the ,http_method.

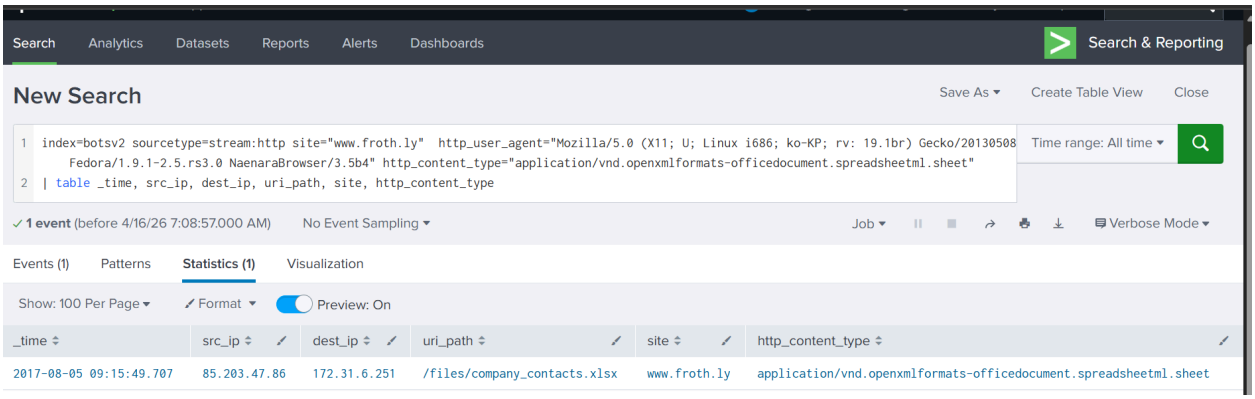




The http_centent_type show the information that was accessed by the adversary, The most interesting type of information access is a spreadsheet which is unusual. I add the spreadsheet to search to get more details.


```
  http_content_length: 41253
  http_content_type: application/vnd.openxmlformats-officedocument.spreadsheetml.sheet
  http_method: GET
  http_referrer: http://www.froth.ly/
  http_user_agent: Mozilla/5.0 (X11; U; Linux i686; ko-KP; rv: 19.1br) Gecko/20130508 Fedora/1.9.1-2.5.rs3.0
NaenaraBrowser/3.5b4
  protocol_stack: ip:tcp:http
  server: Apache/2.2.15 (CentOS)
  site: www.froth.ly
  src_ip: 85.203.47.86
  src_mac: 0A:96:DA:8D:C8:A1
  src_port: 51527
  status: 200
  time_taken: 1354411
  timestamp: 2017-08-05T08:15:48.785770Z
  transport: tcp
  uri_path: /files/company_contacts.xlsx
```


The query reveal the http_method(GET) i.e. retrieve data, the status (200) i.e. successful the user get the file and the uri_path reveal the exact file the adversary got which is company_contact.



The stolen company contact data can be leveraged for:

- 🎯 Spear Phishing Attacks(Targeting a particular individual or team)
  Highly targeted emails crafted using real employee data
- 💰 Business Email Compromise (BEC)
  Impersonation of executives or finance personnel for fraud
- 🧠 Social Engineering
  Manipulating employees using insider knowledge
- 🔑 Credential Harvesting
  Fake login portals targeting known users
- 🦠 Malware Delivery
  Sending malicious attachments to trusted contacts

Mitigation & Strategic Outcomes

- Removed public access to sensitive internal files (/files/company_contacts.xlsx)
- Enforced authentication and access controls
- Implentation of WAF(to detect and block suscipous user agent)
- Encrypt file at rest and transit(TLS)
- Conducted phishing awareness training
- Alerted employees about possible targeted attacks

- Simulated phishing campaigns to test readiness